

Contactless Payment Frameworks

NFC Relay Attack Analysis & Terminal-Side Countermeasures for Mobile Wallet Tokenization

SCOPE	ISO/IEC 14443 link layer · NFC-A/B handshake · tokenization & cryptogram generation
FOCUS AREAS	Relay attack modeling · RTT / distance-bounding analysis · terminal countermeasures
CLASSIFICATION	Technical Case Study — Defensive / Detection Engineering Track
VERSION	v1.0 · Prepared for Cybersecurity Internship Program

1. Executive Summary & Problem Background

- 1.1 Why This Matters for a SOC / Detection Engineer
- 1.2 Document Roadmap

2. ISO/IEC 14443 Communication Standard

- 2.1 The Four Parts of the Standard
- 2.2 Physical / RF Layer Characteristics
- 2.3 Anti-Collision and UID Acquisition (Part 3)
- 2.4 Transmission Protocol — Part 4 (T=CL)

3. Mobile Wallet Tokenization Architecture

- 3.1 Actors in the Tokenization Ecosystem
- 3.2 Token Provisioning Lifecycle
- 3.3 Why Tokenization Does Not Stop Relay Attacks

4. The NFC Handshake Protocol — Annotated Walkthrough

- 4.1 Step-by-Step Frame Sequence
- 4.2 Relay Insertion Point

5. Challenge-Response & Cryptogram Generation Mechanics

- 5.1 Inputs to Cryptogram Generation
- 5.2 Generation Process (Symmetric-Key Model, MAC-Based)
- 5.3 Why the Cryptogram Survives a Relay Unmodified

6. Temporal Constraints in ISO/IEC 14443

- 6.1 Frame Waiting Time (FWT)
- 6.2 Waiting Time Extension (WTX)
- 6.3 Frame Delay Time (FDT) and the PICC Response Window
- 6.4 Why Native Timing Constraints Are Insufficient Alone

7. Relay Attack Models

- 7.1 Canonical Relay Architecture
- 7.2 Hardware Categories Used in Research & Disclosed Incidents
- 7.3 Threat Actor Profiles
- 7.4 Attack Tree

8. Round-Trip-Time (RTT) Checking & Distance-Bounding Protocols

- 8.1 Core Principle of Distance Bounding
- 8.2 Hancke-Kuhn and Related Protocol Families
- 8.3 Implementation Approaches Seen in the Industry

9. Effectiveness Evaluation of RTT Checking Against Relay Hardware

9.1 Latency Budget Comparison

9.2 Why Naive Application-Layer Timeouts Underperform

9.3 Why Tight Distance-Bounding Performs Better — and Its Limits

10. Recommended Client-Side & Terminal-Side Verification Methods

10.1 Terminal-Side Recommendations

10.2 Issuer / Network-Side Recommendations

10.3 Client / Wallet-Side Recommendations

11. Detection Engineering: Telemetry, Indicators & Monitoring Design

11.1 Candidate Telemetry Fields

11.2 Example Detection Rule Logic

11.3 Sample Monitoring Dashboard Concept

12. Case Study Walkthrough: Simulated Transaction Flow & Trace Logs

12.1 Scenario A — Legitimate Local Tap (Baseline)

12.2 Scenario B — Relayed Transaction (Wi-Fi Direct Link)

12.3 Analyst Interpretation

13. Recommendations for Terminal Developers & Issuers

13.1 Terminal Developer Checklist

13.2 Issuer / Risk-Engineering Checklist

14. Conclusion, References & Appendix

14.1 Conclusion

14.2 References & Further Reading

14.3 Appendix A — Glossary of Key Terms

14.4 Appendix B — Suggested Hands-On Lab Extensions

1. Executive Summary & Problem Background

Contactless payments built on Near Field Communication (NFC) and mobile wallet tokenization (Apple Pay, Google Pay, Samsung Pay, and EMV-compliant contactless cards) have become the dominant in-person payment modality across retail, transit, and peer-to-peer terminals. The security model relies on three pillars: a short-range RF link governed by ISO/IEC 14443, device-side tokenization that replaces the Primary Account Number (PAN) with a single-use or domain-restricted token, and a cryptographic challenge-response exchange that proves possession of a live, proximate card or secure element to the terminal.

The vulnerability examined in this case study does not target the cryptography itself. Tokenization and EMV cryptograms are computationally sound under realistic attacker budgets. Instead, the attack class under study — the **NFC relay attack** — exploits an implicit and frequently unverified assumption baked into the protocol stack: that the card answering a terminal's challenge is physically adjacent to that terminal. By inserting an active relay (a proxy reader near the victim's card and a proxy emulator near the target terminal, bridged over Wi-Fi, Bluetooth, or cellular data), an attacker can transparently forward the ISO/IEC 14443 frame exchange across an arbitrary distance, tricking the terminal into believing the legitimate card is present when it may be kilometers away.

NOTE: This case study treats the relay attack as a **protocol-layer transparency problem**, not a cryptographic break. The cryptogram the terminal receives is genuine and would validate correctly — the issue is that the terminal cannot distinguish a genuine local tap from a faithfully relayed remote tap purely from the contents of the messages.

1.1 Why This Matters for a SOC / Detection Engineer

Although NFC relay attacks are executed at the physical/RF layer — outside the visibility of a typical SIEM — the operational consequences land squarely in fraud operations, card-issuer risk teams, and SOC-adjacent detection engineering. Issuers and acquirers build behavioral and timing-based detection layers precisely because cryptographic controls alone cannot stop relay attacks. Understanding the RF-layer mechanics is what allows a detection engineer to design meaningful telemetry, thresholds, and anomaly models at the transaction-processing layer — which is the deliverable this case study builds toward.

1.2 Document Roadmap

- **Section 2** — ISO/IEC 14443 protocol fundamentals: physical layer, anti-collision, and frame structure.
- **Section 3** — Mobile wallet tokenization architecture and the cryptographic token lifecycle.
- **Section 4** — The NFC handshake protocol walkthrough with annotated frame sequences.
- **Section 5** — Challenge-response and cryptogram generation mechanics.
- **Section 6** — Temporal constraints in ISO/IEC 14443 and relay feasibility.
- **Section 7** — Relay attack models: hardware architectures, threat actors, and attack trees.
- **Section 8** — Round-Trip-Time (RTT) checking and distance-bounding protocol analysis.
- **Section 9** — Effectiveness evaluation of RTT checking against real relay hardware.

- **Section 10** — Recommended client-side and terminal-side verification methods.
- **Section 11** — Detection engineering: telemetry, indicators, and monitoring design.
- **Section 12** — Case study walkthrough with simulated transaction flow and trace logs.
- **Section 13** — Recommendations for terminal developers and issuers.
- **Section 14** — Conclusion, references, and appendix.

2. ISO/IEC 14443 Communication Standard

ISO/IEC 14443 is the foundational standard for proximity-coupled smart cards and is the physical and link-layer basis for EMV contactless payments, mobile wallet provisioning, and most transit fare cards. It is published in four parts, each governing a distinct layer of the stack.

2.1 The Four Parts of the Standard

Part	Title	Scope
Part 1	Physical characteristics	Card dimensions, mechanical tolerances, exposure to electromagnetic fields.
Part 2	RF power and signal interface	13.56 MHz carrier, modulation (Type A: modified Miller/OOK; Type B: NRZ-L/BPSK), bit rates.
Part 3	Initialization & anti-collision	Polling, UID retrieval, anti-collision loop, protocol activation (ATQA/ATQB, SAK/ATTRIB).
Part 4	Transmission protocol	Half-duplex block transmission (T=CL), frame waiting time, chaining, error handling.

2.2 Physical / RF Layer Characteristics

The proximity coupling device (PCD — the terminal/reader) generates a 13.56 MHz carrier wave and inductively couples power and clock to the proximity card (PICC). Passive PICCs have no independent power source; they draw operating energy from the field itself, which is precisely why the practical read range is constrained to roughly 4-10 centimeters for full power transfer and reliable load modulation. This short native range is the first (weak) line of defense against relay attacks — it forces an attacker to position a proxy reader within centimeters of the victim's card, which has real-world operational implications for attack delivery.

- **Type A** — Modified Miller coding for PCD→PICC and Manchester-coded subcarrier load modulation for PICC→PCD. Predominant in EMV contactless cards.
- **Type B** — NRZ-L coding with BPSK subcarrier modulation; lower modulation depth, marginally more robust to certain noise profiles.
- **Bit rate** — Baseline 106 kbit/s, with optional higher rates (212/424/848 kbit/s) negotiated during the PPS (Protocol and Parameter Selection) phase.

2.3 Anti-Collision and UID Acquisition (Part 3)

Before any payment-relevant data is exchanged, the PCD must isolate a single PICC from potentially several cards in the field. This happens through REQA/WUPA (Type A) or REQB/WUPB (Type B) polling commands, followed by a bitwise anti-collision loop that incrementally resolves the card's Unique Identifier (UID) when multiple cards respond simultaneously. From a relay-attack perspective, this phase matters because it is the first point where a proxy reader must faithfully reproduce real RF timing — any anti-collision-stage relay must already preserve frame timing to avoid PICC-side Frame Waiting Time (FWT) violations.

Figure 2.1 — Simplified ISO/IEC 14443 layer stack as applied to an EMV contactless transaction

```
+-----+
| Application Layer (EMV Contactless Kernel / Wallet) |
+-----+
| Part 4: Transmission Protocol (T=CL half-duplex) |
| - Block format, chaining, WTX, FWT enforcement |
+-----+
| Part 3: Initialization & Anti-Collision |
| - REQA/WUPA, UID resolution, SAK, ATS |
+-----+
| Part 2: RF Power & Signal Interface (13.56 MHz) |
| - Modulation, coding, bit rate negotiation |
+-----+
| Part 1: Physical Characteristics |
| - Card form factor, field exposure limits |
+-----+
```

2.4 Transmission Protocol — Part 4 (T=CL)

Part 4 defines a half-duplex block transmission protocol analogous to ISO/IEC 7816's T=1 protocol for contact cards, adapted for the contactless link. Three frame types exist: I-blocks (information), R-blocks (acknowledgement/retransmission requests), and S-blocks (supervisory, e.g. Waiting Time Extension and deselect). Each block carries a timing budget enforced by the **Frame Waiting Time (FWT)**, discussed in depth in Section 6, which is the principal native timing safeguard that relay attacks must operate within.

■ **CAUTION:** A common misconception is that FWT alone prevents relay attacks. In practice, FWT is calibrated for legitimate worst-case processing latency (slow secure elements, retries), and most commercial relay setups using low-latency links (sub-50ms) remain comfortably inside vendor-configured FWT budgets — this is explored quantitatively in Section 9.

3. Mobile Wallet Tokenization Architecture

Tokenization is the architectural control that makes contactless and mobile wallet payments safe to expose over an inherently broadcastable RF medium. Rather than transmitting the cardholder's actual Primary Account Number (PAN), the device transmits a surrogate value — the **Device Account Number (DAN)** or payment token — that is cryptographically bound to a specific device, a specific payment network token vault entry, and (for card networks implementing domain restriction) a specific class of merchant or channel.

3.1 Actors in the Tokenization Ecosystem

Actor	Role
Token Requestor	The wallet provider (Apple, Google, Samsung) or issuer app that requests a token on behalf of a device.
Token Service Provider (TSP)	Typically the card network (Visa Token Service, Mastercard MDES). Issues and maps tokens to real PANs in a secure vault.
Issuer	The cardholder's bank; approves provisioning, supplies risk data, and ultimately authorizes the transaction.
Secure Element / HCE	On-device storage for keys — either a dedicated hardware Secure Element (SE) or, on Android, Host Card Emulation (HCE) with cloud-backed keys.
Acquirer / Terminal	The merchant-side payment terminal and its processor, which receives the token and cryptogram and forwards them for authorization.

3.2 Token Provisioning Lifecycle

- **1. Card addition** — User adds a PAN to the wallet app; the app collects device and account data and forwards a provisioning request to the Token Requestor.
- **2. Identification & Verification (ID&V)** — The issuer validates the request via one or more channels (SMS OTP, app-based approval, call center) to confirm the legitimate cardholder is provisioning the card, mitigating enrollment fraud.
- **3. Token generation** — The TSP generates a DAN, distinct from the real PAN, and binds it to the specific device identifier and wallet account in the token vault.
- **4. Key provisioning** — Device-specific limited-use keys (LUKs) are provisioned to the Secure Element or HCE-backed cloud key store. These keys are scoped with usage counters and/or time validity windows.
- **5. Active use** — At the point of sale, the device generates a per-transaction dynamic cryptogram using the LUK, the token, and transaction-specific data (amount, terminal nonce, transaction counter).

Figure 3.1 — Tokenization data flow from PAN to terminal-presented cryptogram


```
Real PAN --(provisioning + ID&V)--> Token Service Provider (TSP)
|
v
Token (DAN) + Limited-Use-Key (LUK)
|
(provisioned to Secure Element / HCE)
|
v
[ Device generates dynamic cryptogram ]
Inputs: LUK, token, txn counter,
terminal unpredictable number,
amount, currency code
|
v
Token + Cryptogram --> Terminal (PCD) --> Acquirer
|
v
Network de-tokenizes &
forwards real PAN-mapped
auth request to Issuer
```

3.3 Why Tokenization Does Not Stop Relay Attacks

It is critical to understand precisely what tokenization protects against, because this case study's central thesis hinges on the distinction. Tokenization protects against **PAN exposure** — if the token and cryptogram are intercepted, they cannot be reused outside their narrow validity window or replayed to a different transaction context. It does *not* protect against **session relaying**, where the attacker does not need to know or extract the underlying secret at all. The attacker simply forwards the live RF exchange — challenge and response alike — between a real card and a real terminal, neither of which is compromised cryptographically. The token vault, the LUK, and the cryptogram all function exactly as designed; the only thing subverted is the implicit proximity assumption.

NOTE: Analogy: tokenization is like giving a courier a sealed, single-use authorization envelope instead of your actual signature. A relay attack does not forge the envelope — it simply walks the real envelope, sealed and untouched, from the real signer to a distant location faster than should be physically possible.

4. The NFC Handshake Protocol — Annotated Walkthrough

This section traces a complete contactless EMV transaction from field activation through application selection, annotating each frame exchange with its protocol purpose and its relevance to relay-attack feasibility.

4.1 Step-by-Step Frame Sequence

Step	Exchange	Purpose
1	PCD → PICC: REQA / WUPA	Terminal polls the field for any Type A card; wakes a card from HALT state if needed.
2	PICC → PCD: ATQA	Card answers with bit-frame anti-collision info and supported bit rates.
3	PCD ↔ PICC: Anti-collision loop	Iterative UID cascade resolves a single card's UID when multiple PICCs are present.
4	PCD → PICC: Select (SAK response)	Card is selected; SAK indicates UID completeness and protocol support (ISO 14443-4 compliance bit).
5	PCD ↔ PICC: RATS / ATS	Request for Answer To Select; PICC returns ATS describing FWT, frame size (FSD/FSC), and protocol options.
6	PCD → PICC: SELECT PPSE	Application-layer command requesting the Proximity Payment System Environment directory (EMV contactless).
7	PICC → PCD: PPSE response	List of supported payment applications (AIDs) on the card/device.
8	PCD → PICC: SELECT AID	Terminal selects the specific application (e.g. Visa, Mastercard contactless kernel).
9	PCD → PICC: GET PROCESSING OPTIONS (GPO)	Terminal sends transaction data (amount, unpredictable number) to initiate processing.
10	PICC → PCD: AIP / AFL + dynamic data	Card returns Application Interchange Profile, Application File Locator, and begins cryptogram generation.
11	PCD ↔ PICC: READ RECORD(s)	Terminal reads remaining application data records as indicated by AFL.
12	PICC → PCD: Dynamic cryptogram (CDA/ARQC-equivalent)	Card returns the transaction cryptogram bound to the unpredictable number and transaction counter.

Figure 4.1 — Annotated frame timeline (logical view, not to time scale)

```

PCD PICC / Wallet
|---- REQA ----->|
|<--- ATQA -----|
|---- Anti-collision (UID cascade) ----->|
|<--- UID, SAK -----|
|---- RATS ----->|
|<--- ATS (FWT, FSD/FSC) -----|
|---- SELECT PPSE ----->|
|<--- AID list -----|
|---- SELECT AID ----->|
|---- GPO (amount, UN) ----->|
|<--- AIP, AFL -----|
|---- READ RECORD(s) ----->|
|<--- Application data -----|
|<--- Dynamic cryptogram (bound to UN, ATC) -----|
|---- (terminal forwards to acquirer for auth) ----->|

```

4.2 Relay Insertion Point

An NFC relay attack inserts itself transparently at every step above. A **proxy reader** (mole/leech device) emulates a PCD next to the victim's real card, while a **proxy card emulator** (ghost device) emulates a PICC next to the real terminal. Every frame the real terminal sends to 'the card' is actually captured by the ghost device, forwarded over an IP link to the mole device, replayed verbatim to the real card, and the real card's response makes the return trip. Because the protocol is fully transparent at the application layer — no field in any of the twelve steps above encodes a proof of physical proximity — the relay is, from the terminal's perspective, indistinguishable from a legitimate local tap, *except for the added latency*, which is the single observable artifact the entire defensive strategy in this report is built around.

5. Challenge-Response & Cryptogram Generation Mechanics

The cryptographic core of a contactless EMV transaction is a challenge-response exchange that produces a transaction-unique Application Cryptogram. This section details the inputs, the generation process, and why the cryptogram's strength is irrelevant to relay-attack resistance.

5.1 Inputs to Cryptogram Generation

Input	Source	Purpose
Unpredictable Number (UN)	Terminal, generated fresh per transaction	Prevents simple replay of a previously captured cryptogram.
Application Transaction Counter (ATC)	Card/device, monotonically incremented	Provides issuer-side sequence tracking and replay detection.
Amount & Currency Code	Terminal, from the GPO command	Binds the cryptogram to the specific transaction value.
Limited-Use Key (LUK) / Session Key	Provisioned to Secure Element / HCE	Symmetric (or derived asymmetric) key material unique to the device-token pairing.
Token (DAN)	Token vault, provisioned at enrollment	Surrogate account identifier in place of the real PAN.

5.2 Generation Process (Symmetric-Key Model, MAC-Based)

Most deployed mobile-wallet implementations use a symmetric-key Message Authentication Code (MAC) construction analogous to the EMV ARQC, computed over a concatenation of the transaction-specific fields. Conceptually:

```
Cryptogram = MAC(LUK, ATC || UN || Amount || Currency || AID || ...)
```

Where:

```
LUK = Limited-Use Key, device + token specific  
ATC = Application Transaction Counter (anti-replay)  
UN = Terminal's Unpredictable Number (freshness)  
Amount = Transaction amount as sent in GPO
```

Some implementations (e.g. EMV CDA — Combined DDA/Application Cryptogram Generation) layer an asymmetric digital signature on top of the symmetric cryptogram, allowing the terminal itself to perform partial offline verification rather than relying purely on the issuer's online check.

5.3 Why the Cryptogram Survives a Relay Unmodified

Crucially, every one of the inputs above is faithfully delivered to the real card by the relay — the UN is real, the amount is real, the ATC is the card's genuine counter value. The card computes a completely legitimate

cryptogram exactly as it would for an in-person tap, because from the card's internal state machine, the relay is indistinguishable from a normal terminal interaction conducted at slightly higher latency. The issuer-side cryptogram validation will therefore **pass**. This is the crux of why relay attacks are categorized separately from cryptographic attacks: no key is broken, no algorithm is weakened, and no MAC forgery occurs.

■ **CAUTION:** Any defense strategy that only strengthens the cryptogram (longer keys, additional MAC rounds, post-quantum primitives) provides zero marginal protection against relay attacks. The countermeasure space must operate at the timing/physical layer, not the cryptographic layer — this motivates Sections 8-10.

6. Temporal Constraints in ISO/IEC 14443

ISO/IEC 14443-4 defines explicit timing parameters that govern how long a PICC may take to respond to a PCD command before the exchange is considered failed. These parameters were designed for reliability — accommodating slow secure elements and noisy RF environments — not for security, but they are the only native temporal signal a relay attack must respect, which makes them the foundation for RTT-based countermeasures.

6.1 Frame Waiting Time (FWT)

FWT is the maximum time the PCD will wait for the PICC to begin its response after the end of the PCD's command frame. It is computed from the Frame Waiting Time Integer (FWI), a 4-bit value (0-14) returned in the ATS during activation:

```
FWT = (256 * 16 / fc) * 2FWI seconds
```

```
Where fc = 13.56 MHz (the ISO 14443 carrier frequency)
```

```
Example: FWI = 4 -> FWT = (256*16/13.56e6) * 24 ≈ 4.8 ms
```

```
Example: FWI = 8 -> FWT = (256*16/13.56e6) * 28 ≈ 77 ms
```

```
Example: FWI = 11 -> FWT ≈ 618 ms (common upper bound for EMV kernels)
```

EMV contactless kernels typically negotiate FWI values that yield FWT budgets in the tens to low hundreds of milliseconds, with some implementations allowing extension via Waiting Time Extension (WTX) S-blocks for slow cryptographic operations. This wide budget exists precisely to tolerate legitimate worst-case secure element processing time — and it is exactly this generosity that creates room for a relay's added round-trip latency to hide undetected.

6.2 Waiting Time Extension (WTX)

If a PICC needs more time than the negotiated FWT (e.g. performing an expensive asymmetric signature for CDA), it may issue an S(WTX) request asking the PCD for additional time, scaled by a multiplier. While intended for legitimate slow processing, a poorly designed terminal implementation that grants WTX requests liberally inadvertently widens the timing window an attacker's relay link can occupy without triggering a timeout.

6.3 Frame Delay Time (FDT) and the PICC Response Window

FDT governs the precise window in which the PICC must begin its load-modulated response relative to the PCD's carrier, synchronized to specific bit boundaries to maintain subcarrier phase coherence. This parameter is tightly bound to the RF physical layer and is largely outside the relay's control surface to manipulate; however, it is also not where most practical relay-attack research has focused, since FWT (the application-level budget) is the looser and more exploitable constraint.

6.4 Why Native Timing Constraints Are Insufficient Alone

Factor	Effect on Relay Feasibility
Generous FWT budgets (tens-hundreds of ms)	Far exceeds the sub-20ms latency achievable with modern Wi-Fi Direct or Bluetooth LE relay links.
WTX extension support	Can be abused to buy additional margin if the relay link is congested or high-latency.
No mandated maximum total transaction time at the application layer	EMV kernels generally do not enforce an aggregate ceiling across the full multi-step exchange, only per-frame.
No cryptographic binding of timing to the cryptogram	The cryptogram contains no timestamp or elapsed-time field, so the issuer cannot detect a relay purely from the authorization message.

NOTE: The takeaway for Sections 7-10: native ISO/IEC 14443 timing exists for reliability, not security. Effective relay countermeasures require *additional*, purpose-built distance-bounding logic layered on top of — not relying on — the standard's existing FWT/FDT mechanisms.

7. Relay Attack Models

This section maps the threat landscape: the hardware architectures used to mount NFC relay attacks, the realistic threat actors and their capabilities, and an attack-tree decomposition of the steps required for a successful unauthorized transaction.

7.1 Canonical Relay Architecture

A relay attack requires two cooperating devices bridged by a data link of the attacker's choosing:

- **Leech / Mole device** — Positioned near the victim's card or unlocked phone (commonly inside a crowded venue, on public transit, or via a compromised point-of-sale accessory). Emulates a PCD to wake and interrogate the victim's card.
- **Ghost / Proxy device** — Positioned at the attacker-controlled point of sale. Emulates a PICC, presenting itself to the real terminal as the victim's card.
- **Relay link** — Any IP-capable channel: Wi-Fi Direct, Bluetooth Low Energy, tethered cellular data, or even a wired LAN if both devices are attacker-controlled and co-located in a lab/test setting.

Figure 7.1 — Canonical two-proxy relay architecture

```
[Victim's Card/Phone] [Real Merchant Terminal]
| (NFC, <10cm) | (NFC, <10cm)
v v
[Leech / Mole] <==== IP Relay Link ====> [Ghost / Proxy]
(acts as PCD (acts as PICC
to the card) to the terminal)

Data path: Terminal command --> Ghost --> [link] --> Mole --> Card
Card response --> Mole --> [link] --> Ghost --> Terminal
```

7.2 Hardware Categories Used in Research & Disclosed Incidents

Category	Example Tooling Class	Characteristics
Proxmark-class SDR/RFID research devices	Software-defined RFID transceivers	Full control over ISO 14443 timing; used extensively in academic relay-attack research.
Off-the-shelf NFC-capable smartphones	Android HCE + reader-mode apps	Lower cost, higher accessibility; relay apps have been demonstrated in academic proof-of-concepts.
Custom microcontroller + NFC front-end	PN532/PN533-based rigs	Common in DIY/academic relay demonstrations; moderate latency overhead.
Dedicated relay-attack research platforms	Lab-built dual-radio rigs	Used in peer-reviewed timing studies to characterize achievable relay latency.

NOTE: This report deliberately discusses hardware categories at a level consistent with published academic literature and does not provide build instructions, firmware, source code, or configuration details for assembling relay hardware. The objective is threat-model awareness for defenders, not attacker enablement.

7.3 Threat Actor Profiles

Actor Profile	Capability	Likely Targets
Opportunistic individual	Single relay rig, manual operation, close physical proximity required for the leech device	Unattended unlocked phones, crowded transit, contactless cards left in bags/wallets
Organized retail fraud crew	Multiple rigs, coordinated timing, repeat operations at high-traffic merchant locations	Self-checkout terminals, unattended kiosks, fuel pumps
Insider-assisted attacker	Access to merchant-side hardware, ability to plant a ghost device inside a compromised terminal	Any merchant the insider has physical access to

7.4 Attack Tree

Figure 7.2 — Decomposition of a successful relay-attack transaction

```
GOAL: Complete unauthorized contactless transaction via relay
|
+-- 1. Achieve RF proximity to victim's card/device
|   +-- 1a. Close-proximity opportunistic contact (crowd, transit)
|   +-- 1b. Planted/disguised leech device (compromised accessory)
|
+-- 2. Establish low-latency bidirectional relay link
|   +-- 2a. Wi-Fi Direct / local network (lowest latency)
|   +-- 2b. Bluetooth LE (moderate latency)
|   +-- 2c. Cellular data (highest latency, least reliable for relay)
|
+-- 3. Faithfully forward full ISO 14443 frame sequence
|   +-- 3a. Anti-collision & UID relay
|   +-- 3b. ATS/RATS negotiation relay
|   +-- 3c. Application-layer (PPSE/AID/GPO/cryptogram) relay
|
+-- 4. Remain within negotiated FWT / WTX timing budget at every step
|
+-- 5. Real terminal accepts cryptogram as valid; transaction authorized
```

8. Round-Trip-Time (RTT) Checking & Distance-Bounding Protocols

Because cryptographic content cannot reveal a relay, the academic and industry response has centered on **distance-bounding protocols** — techniques that measure the round-trip time of specific challenge-response exchanges and reject responses that arrive later than physically possible for a legitimate, proximate card.

8.1 Core Principle of Distance Bounding

A distance-bounding protocol has the verifier (terminal) send a fast, unpredictable challenge bit-string and start a high-resolution timer. The prover (card) must reply within a bounded number of processing cycles. Because RF propagation occurs at the speed of light and the card's processing delay is assumed to have a known minimum, the verifier can derive an upper bound on the physical distance to the prover:

```
d_max = (t_round_trip - t_processing) * c / 2
```

Where:

t_round_trip = measured time from challenge sent to response received

t_processing = card's assumed/declared internal processing delay

c = speed of light (~3x10⁸ m/s)

At native 13.56 MHz NFC bit rates, even a few microseconds of added relay latency corresponds to tens to hundreds of meters of implied distance -- far beyond the legitimate ~10cm operating range.

8.2 Hancke-Kuhn and Related Protocol Families

Academic literature (notably the Hancke-Kuhn distance-bounding protocol and its derivatives) proposes bit-by-bit rapid challenge-response rounds specifically designed to minimize the prover's processing delay to a fixed, tightly bounded number of clock cycles, so that any added relay latency becomes the dominant — and therefore detectable — component of the measured round-trip time. EMV-specific adaptations have been proposed (and partially piloted by some payment networks) layering a similar rapid timing check on top of the standard contactless kernel flow, typically inserted around the GPO/cryptogram exchange.

8.3 Implementation Approaches Seen in the Industry

Approach	Mechanism	Maturity
Terminal-side RTT thresholding	Terminal measures total or per-frame round-trip time and flags/declines transactions exceeding a calibrated threshold	Piloted by some networks; not universally mandated
Card-side processing-time normalization	Secure element enforces a constant, minimal response delay so timing variance is attributable mainly to RF/relay latency	Partial adoption in newer secure element firmware

Approach	Mechanism	Maturity
Dedicated distance-bounding command set	New ISO/IEC and EMVCo proposals defining bit-level rapid exchanges purpose-built for proximity proof	Standards-track / research stage as of this writing

9. Effectiveness Evaluation of RTT Checking Against Relay Hardware

This section synthesizes published timing-measurement studies into a structured evaluation of how well RTT-based countermeasures actually perform against realistic relay hardware, and where the residual gaps lie.

9.1 Latency Budget Comparison

The defensibility of RTT checking hinges on whether the added latency from a relay link is reliably distinguishable from the natural jitter of a legitimate local tap. The table below summarizes illustrative latency orders-of-magnitude drawn from general relay-attack timing literature.

Link Type	Typical Added Latency	Caught by Naive FWT Timeout?	Caught by Tight RTT Bound?
Legitimate local tap	~0 (baseline)	N/A	N/A
Wired LAN relay (lab conditions)	Sub-ms to low ms	No	Often, with a tight bound
Wi-Fi Direct relay	Low single-digit ms	No	Yes, with sub-ms resolution
Bluetooth LE relay	Several to tens of ms	Usually no (within generous FWT)	Yes
Cellular-data relay	Tens to hundreds of ms	Sometimes (may approach FWT ceiling)	Yes, easily

9.2 Why Naive Application-Layer Timeouts Underperform

As established in Section 6, standard EMV FWT budgets are generous enough (tens to hundreds of milliseconds) that low-latency relay links — particularly Wi-Fi Direct and well-optimized Bluetooth LE setups — frequently complete the entire relayed exchange within the existing timeout window. **Naive application-layer timeout checking is therefore an insufficient standalone control.** It catches only the slowest, least competent relay implementations.

9.3 Why Tight Distance-Bounding Performs Better — and Its Limits

Purpose-built distance-bounding rounds (Section 8.2) achieve much finer timing resolution because they are engineered to make the card's own processing delay negligible and constant, isolating relay-induced latency as the dominant signal. Published research on this protocol family generally reports strong discriminative power against relay attacks under laboratory conditions. However, several practical limitations constrain real-world effectiveness:

- **Backward compatibility** — Tight distance-bounding requires new card/terminal firmware capable of the rapid-bit-exchange rounds; the existing global terminal fleet cannot be upgraded instantly, creating a long mixed-mode transition period.

- **Clock and hardware variance** — Real-world secure elements and terminal RF front-ends exhibit manufacturing and thermal timing variance, forcing a non-zero safety margin into the bound, which an optimized relay can sometimes still fit within.
- **Cost of false positives** — Overly aggressive thresholds risk declining legitimate transactions from cards with slower (but legitimate) secure elements, creating a customer-experience/fraud-prevention tradeoff issuers must tune carefully.
- **No public, universal deployment yet** — As of this writing, tight distance-bounding is a research/early-pilot capability rather than a globally mandated EMV requirement, leaving most of the existing terminal base reliant on the weaker naive-timeout model.

■ **CAUTION:** Conclusion of the effectiveness evaluation: RTT checking is **necessary but, in its currently most-deployed naive form, not sufficient**. Meaningful relay-attack resistance requires combining tight distance-bounding (where deployed) with the complementary terminal- and issuer-side controls developed in Sections 10-11.

10. Recommended Client-Side & Terminal-Side Verification Methods

This section consolidates the case study's recommendations into a layered defense model. No single control is sufficient (Section 9); resilience comes from combining RF-layer, application-layer, and back-end risk-engine controls.

10.1 Terminal-Side Recommendations

Control	Description	Defends Against
Tight RTT / distance-bounding rounds	Adopt EMVCo/ISO distance-bounding extensions where supported by the terminal vendor and card population	Low-latency relay links (Wi-Fi Direct, optimized BLE)
Reduced, calibrated FWT/FWI negotiation	Negotiate the tightest FWI the legitimate card population can reliably support, rather than defaulting to maximal vendor values	High-latency relay links (cellular, congested BLE)
Per-frame timing logging	Log granular timestamps for each frame in the transaction, not just total transaction time, to enable post-hoc anomaly analysis	All relay variants (enables detection even when not blocked in real time)
WTX rate limiting	Cap the number and cumulative duration of Waiting Time Extension grants per transaction	Relay links attempting to buy extra margin via WTX abuse
Multi-tap consistency checks	Where supported, compare RF signal characteristics (signal strength profile, modulation depth) against expected passive-card profiles	Active relay/proxy emulator hardware, which has different RF signatures than a passive card

10.2 Issuer / Network-Side Recommendations

- **Velocity and geo-impossibility checks** — Flag transactions where the same token is used in geographically inconsistent locations within an implausibly short window.
- **Device-binding consistency** — Cross-check device telemetry (where available, e.g. from the wallet provider) against the location and timing of the presented transaction.
- **Step-up authentication for risk-scored transactions** — Trigger additional verification (PIN, biometric re-prompt) when timing or behavioral signals suggest possible relay activity, balancing friction against fraud loss.
- **Issuer-side ATC gap analysis** — Monitor for unusual Application Transaction Counter patterns that may correlate with relay-enabled fraud rings operating across multiple compromised cards.

10.3 Client / Wallet-Side Recommendations

- **Explicit user-presence confirmation** — Require biometric or passcode confirmation immediately before each tap rather than relying solely on a device-unlocked state, narrowing the window in which a leech device

could interact with an unattended unlocked phone.

- **Transaction amount display & confirmation** — Surface the transaction amount on-device before the cryptogram is released, giving the user a final chance to notice an unexpected or out-of-context payment prompt.
- **Background NFC field-detection alerts** — Notify the user if the device's NFC radio is activated while the device is locked or while no wallet app is in the foreground, surfacing potential leech-device interactions.

NOTE: No single layer in this model is claimed to be complete. The terminal-side RTT layer directly addresses the RF-layer transparency problem identified in Section 5.3; the issuer-side layer provides a backstop for relay attacks that evade RTT bounds; the client-side layer raises the operational cost of acquiring leech-device proximity in the first place.

11. Detection Engineering: Telemetry, Indicators & Monitoring Design

This section translates the technical analysis into a concrete detection-engineering deliverable — the kind of artifact a SOC or fraud-operations detection engineer would actually build and present, directly extending the defensive/detection focus established for this case study.

11.1 Candidate Telemetry Fields

Field	Source	Why It Matters
per_frame_rtt_ms	Terminal firmware / acquirer gateway logs	Primary signal for relay-latency anomalies; needs per-frame granularity, not just total transaction time.
fwi_negotiated	ATS response, captured by terminal	Establishes the legitimate timing budget against which observed RTT should be compared.
wtx_count / wtx_total_ms	Terminal protocol stack	Detects abuse of Waiting Time Extension to mask relay latency.
geo_velocity_flag	Issuer transaction processing system	Flags physically impossible travel between consecutive uses of the same token.
device_lock_state_at_tap	Wallet provider telemetry (where available)	Detects taps occurring while the device was reported locked, suggesting possible leech-device interaction.
terminal_class / merchant_risk_tier	Acquirer merchant database	Self-checkout and unattended kiosks warrant tighter thresholds given historical relay-fraud concentration.

11.2 Example Detection Rule Logic

The following is illustrative detection logic in the same spirit as a SIEM correlation rule or fraud-engine scorecard entry — combining the RTT signal with corroborating context rather than relying on RTT alone, consistent with the layered-defense conclusion of Section 10.


```
RULE: possible_nfc_relay_transaction

CONDITION:
per_frame_rtt_ms[any_frame] > (fwi_expected_ms * 0.6)
AND wtx_count >= 1
AND terminal_class IN ('self_checkout','unattended_kiosk')

SEVERITY:
HIGH if geo_velocity_flag == true
MEDIUM if device_lock_state_at_tap == 'locked'
LOW otherwise (log for trend analysis, no immediate action)

ACTION:
HIGH/MEDIUM -> step-up auth on next transaction attempt for this token
-> open fraud-ops case with full per-frame RTT trace attached
LOW -> aggregate into weekly merchant-terminal anomaly trend report
```

11.3 Sample Monitoring Dashboard Concept

A practical portfolio deliverable extending this case study would be a dashboard surfacing: (a) distribution of per-frame RTT across all transactions at a given terminal/merchant over time, with anomalous outliers highlighted; (b) WTX usage rate trend by terminal; (c) geo-velocity flag rate by token/issuer BIN range; and (d) a ranked list of terminals whose RTT distribution has drifted significantly from their own historical baseline — which can indicate either a compromised/ghost-device-equipped terminal or simply degraded hardware needing maintenance.

12. Case Study Walkthrough: Simulated Transaction Flow & Trace Logs

This section presents a fully simulated (synthetic, non-operational) transaction trace illustrating the difference in observable timing between a legitimate local tap and a relayed transaction, structured the way a fraud-operations analyst would review the per-frame log during an investigation.

12.1 Scenario A — Legitimate Local Tap (Baseline)

Synthetic trace log — illustrative values only, not captured from any real system

```
txn_id=SIM-A001 terminal=POS-TERM-0447 terminal_class=staffed_retail
fwi_negotiated=8 (fwt_budget_ms=77)

frame step rtt_ms cumulative_ms
1 REQA/ATQA 0.9 0.9
2 Anti-collision/UID 1.1 2.0
3 RATS/ATS 1.4 3.4
4 SELECT PPSE 2.1 5.5
5 SELECT AID 2.0 7.5
6 GPO 6.3 13.8
7 READ RECORD 2.4 16.2
8 Cryptogram response 3.7 19.9

wtx_count=0 geo_velocity_flag=false device_lock_state=unlocked
RESULT: rtt well within fwt_budget_ms at every frame -> no anomaly flag
```

12.2 Scenario B — Relayed Transaction (Wi-Fi Direct Link)

Synthetic trace log — illustrative values only, not captured from any real system

```
txn_id=SIM-B002 terminal=POS-TERM-9123 terminal_class=self_checkout
fwi_negotiated=8 (fwt_budget_ms=77)

frame step rtt_ms cumulative_ms
1 REQA/ATQA 4.8 4.8
2 Anti-collision/UID 5.2 10.0
3 RATS/ATS 5.6 15.6
4 SELECT PPSE 6.9 22.5
5 SELECT AID 6.5 29.0
6 GPO 14.7 43.7
7 READ RECORD 7.1 50.8
8 Cryptogram response 9.4 60.2

wtx_count=1 (requested during frame 6) geo_velocity_flag=true
device_lock_state_at_tap=locked
RESULT: all frames remain < fwt_budget_ms (77ms) -> naive FWT timeout DOES NOT fire
per_frame_rtt elevated ~5x vs baseline -> tight RTT bound WOULD flag this
geo_velocity_flag=true + device_lock_state=locked -> detection rule (11.2) fires HIGH
```

12.3 Analyst Interpretation

Scenario B illustrates precisely the gap quantified in Section 9: every individual frame remains comfortably inside the negotiated 77ms FWT budget, so a terminal relying solely on native ISO/IEC 14443 timeout enforcement would process this transaction without complaint. The cryptogram itself would validate correctly, since (per Section 5) the relay does not tamper with any cryptographic content. The transaction is only flagged because the detection rule in Section 11.2 combines the elevated — though still FWT-compliant — per-frame RTT with two corroborating contextual signals: a geographically impossible token-usage pattern and a tap occurring while the wallet-bearing device was reported locked. This is the practical justification for the layered-defense conclusion of Section 10: RTT data alone, interpreted in isolation against only the native FWT ceiling, would have missed this relay; RTT data interpreted as a *relative* anomaly against baseline, combined with corroborating context, catches it.

13. Recommendations for Terminal Developers & Issuers

This section distills the case study into an actionable checklist, framed for two audiences: engineers building or certifying payment terminal firmware, and issuer-side risk/fraud engineering teams designing the back-end detection layer.

13.1 Terminal Developer Checklist

- Negotiate the tightest FWI value the certified card population reliably supports; avoid defaulting to maximal vendor-recommended values that widen the relay window.
- Log per-frame timestamps at microsecond resolution, not just aggregate transaction duration, and make this telemetry available to acquirer-side fraud systems.
- Implement WTX rate limiting and log every WTX grant with its requested duration.
- Track and adopt EMVCo / ISO distance-bounding extensions as they mature into certification requirements, prioritizing self-checkout and unattended kiosk deployments where relay-fraud concentration has historically been higher.
- Avoid silently extending timeouts beyond certified FWT/WTX bounds for the sake of reducing customer-facing transaction failures — this trades fraud risk for convenience without disclosure.
- Participate in industry timing-calibration studies so naive single-vendor thresholds are replaced with population-calibrated, statistically grounded bounds.

13.2 Issuer / Risk-Engineering Checklist

- Ingest per-frame RTT telemetry from acquirers where available, rather than relying solely on binary accept/decline signals from the terminal.
- Build baseline RTT distributions per terminal/merchant and alert on statistically significant drift, not just absolute threshold breaches (Section 11.3).
- Combine timing anomalies with geo-velocity and device-state corroboration before declining or step-up-authenticating a transaction, to manage false-positive rates (Section 9.3).
- Maintain a feedback loop from confirmed fraud cases back into rule tuning, since relay-attack tooling and achievable latency continue to evolve.

14. Conclusion, References & Appendix

14.1 Conclusion

NFC relay attacks against contactless payment tokenization exploit a structural gap rather than a cryptographic weakness: ISO/IEC 14443 and EMV contactless kernels were designed for reliable short-range communication, not for proving physical proximity. Tokenization, limited-use keys, and dynamic cryptograms — all of which remain cryptographically sound — do nothing to prevent a faithful, real-time relay of the entire protocol exchange between a legitimate card and a distant terminal. The native timing safeguards in the standard (FWT, FDT, WTX) were calibrated for processing tolerance, not security, leaving a window that low-latency relay links can frequently occupy undetected by naive timeout enforcement alone.

Effective resistance requires a layered model: tighter, purpose-built distance-bounding at the RF/terminal layer; granular per-frame timing telemetry feeding statistically calibrated anomaly detection at the issuer layer; and user-presence and device-state controls at the client layer. No single layer is sufficient on its own, which is precisely why this case study frames the deliverable as a detection-engineering problem as much as a cryptographic or RF-engineering one — directly relevant to a SOC or fraud detection-engineering career track.

14.2 References & Further Reading

The following are the primary standards and well-known academic research families referenced conceptually throughout this case study. Readers should consult the official, current editions for authoritative technical detail.

- ISO/IEC 14443 Parts 1-4 — Identification cards — Contactless integrated circuit cards — Proximity cards (International Organization for Standardization).
- EMV Contactless Specifications for Payment Systems, Books A-D (EMVCo).
- EMVCo Co-Residing Application and Common Payment Application Specifications, covering token-based contactless kernels.
- Hancke, G. and Kuhn, M. — "An RFID Distance Bounding Protocol" and related distance-bounding protocol literature (general academic family, multiple follow-on papers and surveys).
- Francillon, A., Danev, B., and Capkun, S. — published academic work on relay attacks against passive keyless entry and proximity systems, frequently cited as foundational context for RFID/NFC relay-attack research generally.
- EMVCo and payment network public technical bulletins on contactless kernel timing parameters and distance-bounding roadmap items (consult current EMVCo.com publications for the latest status).

NOTE: This report synthesizes publicly known protocol mechanics and widely published academic research directions. It does not reference any non-public, leaked, or proprietary technical material, and intentionally omits implementation-level detail (firmware, exploit code, hardware schematics) that would constitute attacker uplift rather than defensive understanding.

14.3 Appendix A — Glossary of Key Terms

Term	Definition
PCD	Proximity Coupling Device — the reader/terminal side of an ISO/IEC 14443 link.
PICC	Proximity Integrated Circuit Card — the card/device side of an ISO/IEC 14443 link.
FWT	Frame Waiting Time — maximum time a PCD waits for a PICC response before timeout.
FWI	Frame Waiting Time Integer — the 4-bit ATS field from which FWT is derived.
WTX	Waiting Time Extension — supervisory mechanism allowing a PICC to request more processing time.
LUK	Limited-Use Key — device/token-specific symmetric key with bounded usage scope.
DAN	Device Account Number — the tokenized surrogate for the real PAN used in mobile wallets.
ARQC	Authorization Request Cryptogram — EMV term for the transaction cryptogram sent for online authorization.
RTT	Round-Trip Time — elapsed time between sending a challenge and receiving the corresponding response.
Distance bounding	A protocol technique using tightly measured RTT to derive an upper bound on physical distance between two parties.

14.4 Appendix B — Suggested Hands-On Lab Extensions

For an intern or advanced learner extending this case study into a hands-on lab deliverable, the following directions stay within legitimate, defensive research scope and avoid producing attacker-usable tooling:

- Build the detection rule from Section 11.2 as a working script against a synthetic dataset of generated transaction logs (extending the trace-log format from Section 12).
- Build the monitoring dashboard concept from Section 11.3 as a small data-visualization project using simulated per-terminal RTT distributions.
- Write a short technical brief (1-2 pages) translating Sections 8-9 into a recommendation memo for a hypothetical acquirer evaluating whether to invest in distance-bounding-capable terminal hardware, including a rough cost/benefit framing.
- Research and summarize (in your own words, with proper citation) one publicly available academic paper on RFID/NFC distance bounding, focusing on what timing resolution it achieved and under what lab conditions.